**NAME: THULASI S** **ROLL:NO: 241901118**

# EXP 3: PERFORM SESSION HIJACKING USING VARIOUS TOOLS

## AIM:

To understand and demonstrate session hijacking in an authorized lab environment using Ettercap and Wireshark.

## THEORY:

Session hijacking is an attack where an attacker takes over a valid session between a user and a web application, usually by stealing the **session ID / session cookie**. Once the attacker has this session ID, the server thinks the attacker is the legitimate logged-in user.

Common methods of session hijacking:

- Sniffing — capturing session cookies from unencrypted (HTTP) traffic on the same network.
- Man-in-the-Middle (MITM) attack using ARP spoofing — tricking two devices into sending their traffic through the attacker's machine.
- Cross-Site Scripting (XSS) — injecting a script that steals cookies (covered later in Experiment 12).

This experiment focuses on network-level session hijacking using ARP spoofing + packet sniffing, which works when the target website does not use HTTPS.

## TOOLS REQUIRED:

- Kali Linux with Ettercap and Wireshark installed
- A target machine (e.g., Metasploitable2 or a Windows VM) logged into a website over plain HTTP (e.g., DVWA running over HTTP)
- All machines connected to the same virtual lab network (NAT/Host-only network in VirtualBox/VMware)

## PROCEDURE:

Step 1: Set Up the Lab Network

Make sure the Kali attacker machine and the victim machine are on the same subnet (for example, both on a VirtualBox "Host-only" network). Note down both IP addresses using ifconfig.

Step 2: Enable IP Forwarding on Kali (so traffic still reaches its destination)

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

Step 3: Launch Ettercap for ARP Spoofing

Open Ettercap in graphical mode:

```
ettercap -G
```

In the Ettercap window:

1. Go to Sniff → Unified Sniffing, select your network interface (e.g., eth0).
2. Go to Hosts → Scan for Hosts, then Hosts → Hosts List to see all devices on the network.
3. Select the victim's IP and click Add to Target 1.
4. Select the router/gateway IP and click Add to Target 2.
5. Go to Mitm → ARP Poisoning, tick "Sniff remote connections", and click OK.
6. Click the Start button (play icon) to begin sniffing.

This places the attacker machine in the middle of the victim's traffic to the gateway (a Man-in-the-Middle position).

Step 4: Capture Traffic with Wireshark

Open Wireshark on Kali and start capturing on the same interface:

```
wireshark
```

Apply an HTTP filter to see only web traffic:

```
http.request
```

Ask the victim machine to log into the plain-HTTP lab website (e.g., DVWA) during this step.

Step 5: Extract the Session Cookie

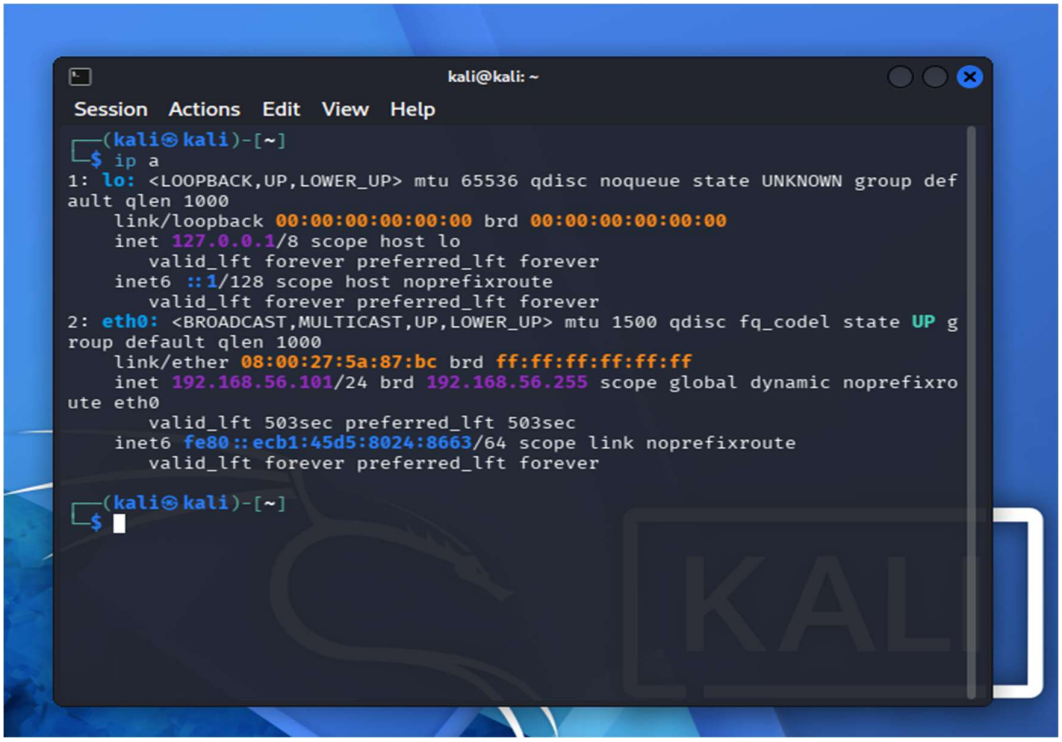
In Wireshark, find the HTTP GET/POST request containing the login, and look at the Cookie field in the HTTP headers (e.g., PHPSESSID=abc123xyz).

Step 6: Reuse the Stolen Session

On the Kali machine, open the same website in a browser, open Developer Tools (F12) → Storage/Application tab → Cookies, and replace the current session cookie value with the one you captured. Refresh the page — you should now be logged in as the victim, without knowing their password.

**OBSERVATION:**

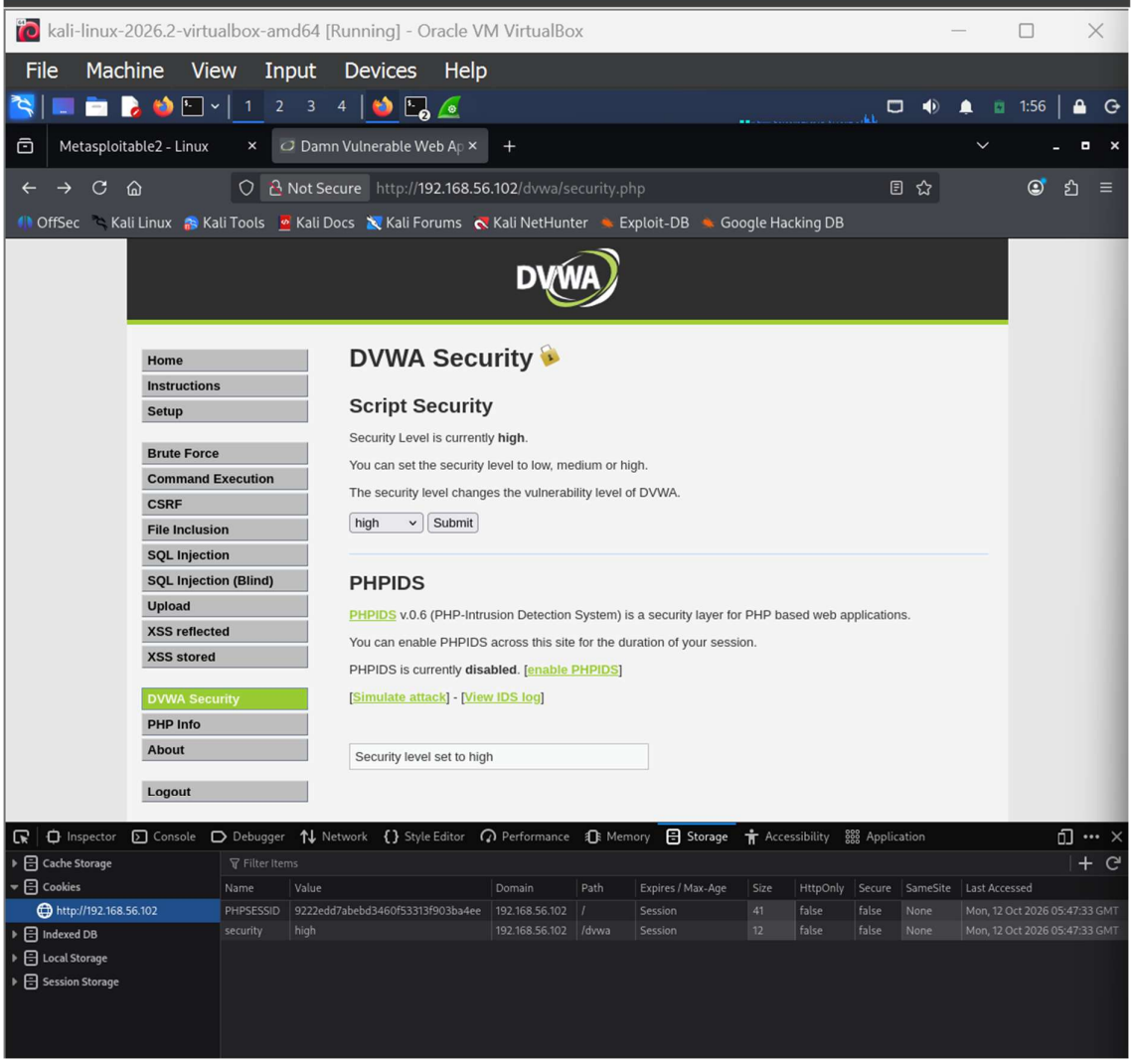
| OBSERVATION | RESULT |
|---|---|
| Kali Linux IP address | 192.168.56.101 |
| Metaspoitable2 IP address | 192.168.56.102 |
| Network connectivity | Successful; 4 packets received with 0% packet loss |
| Wireshark packet capture | HTTP GET requests and HTTP 200 OK responses observed |
| Test application | DVWA opened successfully; loged in as admin |
| Session cookie | PHPSESSID observed in Firefox Storage |
| Cookie security attributes | HttpOnly: false; Secure: false; Samesite: None, displayed in the captured screenshot |
| Session hijacking | No |

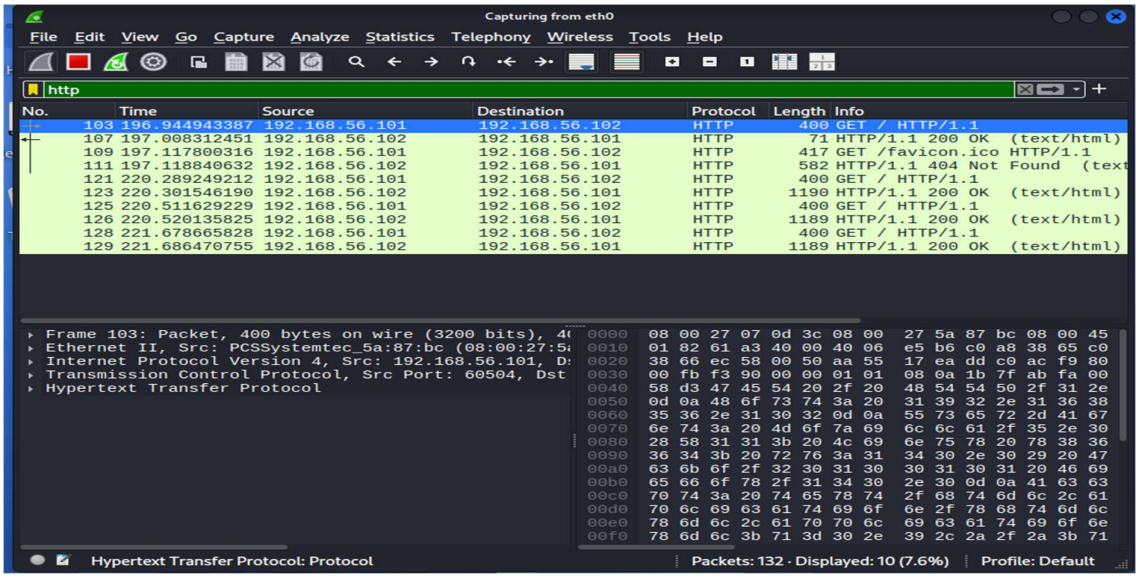


```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:07:0d:3c
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe07:d3c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188 (1.1 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:96 errors:0 dropped:0 overruns:0 frame:0
          TX packets:96 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21437 (20.9 KB)  TX bytes:21437 (20.9 KB)

msfadmin@metasploitable:~$
```






## RESULT:

HTTP traffic was captured and analysed using Wireshark. The DVWA session cookie and its security attributes were inspected using Firefox Developer Tools, and the security risks associated with session hijacking were studied.